

NIP first ARB — 35-minute walk

Talk ~35 minutes. Leave ~25 for the board. Do not fill the hour.

Opening (45 seconds)

Good morning. This is the first architecture review of the Insurance Distribution Platform.

The slot is sixty minutes. I will take about thirty-five to walk the problem, the outcome we are building, and how this architecture does it. The remainder is for you — questions, observations, improvements.

We are not seeking production authority today. We are seeking a recorded review of the intended design so Dev and UAT can be stood up.

If a question needs a measured number we do not have, I will take it as a dated action. I will not guess an IP, a restore time, or a pentest result.

Five plays when you do not know

Play 1 — Cite and stop

That decision is recorded in ADR-0XX. I will not re-litigate it from memory. Happy to walk the clause after the sitting if needed.

Play 2 — Name the owner

The structure is Architecture's. The remaining acceptance sits with [Deepali / Shivanshi / bank network / Apigee team]. I will not speak for their residual.

Play 3 — Action, dated, non-blocking

Fair question. I do not have a measured answer in the room and I will not invent one. Action: we return by [date] with [owner]. That item does not change the Dev/UAT VPC shape we are asking you to review today.

Play 4 — Later sitting

That is a production, DR-readiness or VA-PT question. We will bring evidence to the second ARB. Today is the intended design, so Dev and UAT can be stood up.

Play 5 — Never guess

I will not guess an IP, a pentest result, a restore-drill time, or a CIS register class. Guessing those in this room would be the actual control failure.

Slide 1. Title (1 min · running 1)

SAY: Good morning. This is the first architecture review of the Insurance Distribution Platform.

The slot is sixty minutes. I will take about thirty-five to walk the problem, the outcome we are building, and how this architecture does it. The remainder is for you — questions, observations, improvements.

We are not seeking production authority today. We are seeking a recorded review of the intended design so Dev and UAT can be stood up.

If a question needs a measured number we do not have, I will take it as a dated action. I will not guess an IP, a restore time, or a pentest result.

IF ASKED: If someone asks whether this is production approval — no. Say it once, write it on the parking lot, keep walking.

DO NOT: Do not say the architecture was designed by AI. Do not apologise for the design. Do not promise production in the same breath as Dev.

Slide 2. Purpose of this sitting (1 min · running 2)

SAY: Thirty-five minutes from me so that twenty-five remain for the board. I will show the problem, the R0 outcome, then how a sale, a session, a partner call, identity, money and recovery actually work. Please hold deep dives until the discussion — I will pause after the topology picture if the room is already there.

IF ASKED: If they want network first, skip to 'How a session reaches the application'. The problem slide can wait two minutes.

DO NOT: Do not read a table of timings aloud. Point at the two clocks and move.

Slide 3. Why this platform exists (3 min · running 5)

SAY: This is an insurance distribution problem, not a hosting problem. We hold a composite corporate-agency licence. If we cannot show suitability, customer consent, customer-device payment and a reconciled policy, we do not have a sale we can stand behind. That is why we are not wrapping someone else's portal.

IF ASKED: Health, Motor and DIY are later horizons. Do not design them in this sitting.

DO NOT: Do not invent a Product signature. Rajal owns volumes and business sign-off.

Slide 4. What R0 must deliver (2 min · running 7)

SAY: R0 is narrow on purpose: one RM, one ETB customer, one Group A insurer, assisted Life. Depth over breadth. The five bars on this slide are not features — they are gates. If a shortcut skips one of them, it is not a simplification.

IF ASKED: Volumes are still Product assumptions. They do not change the Dev/UAT network shape.

DO NOT: Do not expand into DIY, hybrid, or a second line of business to look more complete.

Slide 5. How one sale completes (5 min · running 12)

SAY: Forget boxes for a moment — this sequence is the architecture. Flutter never calls the aggregator, never calls the database, never calls Apigee. The customer phone appears twice: OTP and pay. If someone proposes collapsing quote and suitability into one service to look smaller, that is a control failure dressed as simplicity.

IF ASKED: Why several services? Because a later Health journey must not rewrite Life. Different systems of record stay different.

DO NOT: Do not call Kafka the audit log. Do not accept RM-pays-for-the-customer as a UAT exception.

Slide 6. How a session reaches the application (4 min · running 16)

SAY: A session is terminated at the edge, then at API Gateway, then at an internal load balancer. You cannot curl a pod from the internet — that is intentional. If the room asks why not a public ALB, the one-line answer is: it would add a public target in front of a front door we already have. That is ADR-018. Changing it is a Deepali exposure decision, not a Dev convenience. Do not agree to a public ALB 'just for Dev'.

IF ASKED: Use FAQ on public ALB. Play 2 if they insist. Play 3 if they want a redesign in the last twenty minutes.

DO NOT: Do not contrast this with neighbour applications on the slide. Answer that only if asked, from the notes.

Slide 7. How the platform calls a partner (3 min · running 19)

SAY: Two different outsides. Mixing them is how CIF ends up on the public internet. The adapter's base URL is the Apigee proxy, not the aggregator host. Publishing NAT Elastic IPs to 1SB allowlists the wrong host — ADR-020. I will not read out an IP list; that action sits with the Apigee team and does not block vpc-dev.

IF ASKED: Apigee edition and IPs: Play 3, DEP-20260914-apg. Dev uses stubs.

DO NOT: Do not promise the Apigee product exists today. Do not invent IPs.

Slide 8. Where a request runs (3 min · running 22)

SAY: This is the runtime picture. Three facts: we attach as a spoke — we do not build a second hub. Inbound is the path you just saw. Outbound leaves through Apigee. The picture is a rendering of the LLD. If it disagrees with an ADR, the ADR wins. I will pause here if you want to interrogate the drawing; otherwise I will keep moving so we protect discussion time.

IF ASKED: If the drawing is too busy, the previous two slides are the same facts in sequence.

DO NOT: Do not walk every box. Offer the LLD after the sitting.

Slide 9. How Dev and UAT are isolated (2 min · running 24)

SAY: Five accounts. Dev is not a sixth account — it is a VPC inside UAT, with its own route table, namespaces and schemas, so stubs cannot ride a production CBS route. CUG is not in R0; there is no consumer for it. Production is on this picture so you can see blast radius — we are not asking to vendor it today.

IF ASKED: A split Dev account is a Cloud cost exception we are not requesting. We can consume it; we are not asking for it.

DO NOT: Do not offer to vendor production 'while we are here'.

Slide 10. How identity, records and exposure are handled (3 min · running 27)

SAY: Please do not let anyone treat the search cluster as the audit pack. Search can be rebuilt. WORM cannot be shortened because we are in a hurry. We are not binding LDAP from Kubernetes to Active Directory — that would be a new credential path. VA/PT does not exist yet; we will not pentest an environment we have not been allowed to vendor.

IF ASKED: CIS class is a proposal; Shailja and CISO register it. Play 2. Play 4 on pentest.

DO NOT: Do not classify the system into the CIS register from this slide. Do not say pentest is next week unless a date exists.

Slide 11. How premium is collected (3 min · running 30)

SAY: Session-create goes out through Apigee. The customer completes 3-D Secure on their own device. The callback arrives on a separate API Gateway route, not on the RM session. We do not mark sold because a payment API returned 200. We wait for reconciled. If the callback is lost, state is uncertain and we block a second attempt. Timeouts do not mint money.

IF ASKED: PAN never on the RM device and never in our logs. We use the bank payment gateway; we do not replace it.

DO NOT: Do not accept 'RM pays on behalf for the UAT demo' as an architecture exception.

Slide 12. Continuity — designed, not yet drilled (2 min · running 32)

SAY: Three numbers, one caveat: we have not measured them in a drill. That is exactly why this is not the production ARB. Warm standby matches a one-hour RTO. Active-active is a different money and data problem — I will not 'fix' SOP language in this hour without Aarti and Shivanshi.

IF ASKED: Play 4. NFR-DR-04 is the drill.

DO NOT: Do not claim DR is proven. Do not drop Hyderabad 'to save money' without Aarti.

Slide 13. Decision requested (2 min · running 34)

SAY: The decision we are requesting: record this as the intended R0 design, and allow Dev and UAT to be provisioned on this shape. Production authority, DR proof and pentest belong to a later sitting. I will stop here so we can discuss.

IF ASKED: If they will only write 'approved', ask them to qualify: first review, Dev/UAT vending, production ARB still required.

DO NOT: Do not leave without a written observation, even if it is 'no objection to Dev/UAT, firewall remainder with Security'.

Slide 14. Appendix — network terms (appendix)

SAY: Open only if a network SME quizzes terms. You do not need BGP in this sitting.

IF ASKED: Below this table — Play 3, with SRE and bank network.

DO NOT: Do not draw BGP on a whiteboard unless SRE is speaking.

Slide 15. Appendix — if you do not have the number (appendix)

SAY: Memorise Play 3 and Play 5. Put them on a card in your pocket.

DO NOT: Do not present this slide in the main walk.

Close (30 seconds)

The decision we are requesting: record this as the intended R0 design, and allow Dev and UAT to be provisioned on this shape. Production authority, DR proof and pentest belong to a later sitting. I will stop here so we can discuss.

FAQ — for the discussion window

Q1. Why not a public / external ALB like other bank apps?

NIP's AWS entry is API Gateway, then an Internal ALB only (ADR-018). A public ALB in front of that front door adds a public target we do not need. Changing it is a Security exposure decision — not a Dev convenience.

Cite: ADR-018. Do not defer — answer from the ADR.

Q2. Why not put a public ALB in Dev only?

A public Dev is a production-shaped hole. The workload has no internet gateway in every environment. We will not invent a second ingress to go faster.

Cite: ADR-018 / LLD §2. Do not defer — answer from the ADR.

Q3. Why API Gateway and Apigee — two API products?

They do different jobs. API Gateway is inbound for RM/mobile and payment callbacks. Apigee is outbound for 1SB and internal bank APIs (ADR-020). One product doing both hairpins internal APIs through the public edge or allowlists the wrong IPs at 1SB.

Cite: ADR-020. Do not defer — answer from the ADR.

Q4. Why not Apigee on the front door instead of API Gateway?

Inbound stays API Gateway. Drawing Apigee on ingress puts RM traffic on the outbound plane. We will not redesign that in this sitting.

Cite: ADR-020. Do not defer — answer from the ADR.

Q5. Why no Internet Gateway on the workload VPC?

If a workload VPC has an IGW, someone will eventually attach a public IP. The only IGW is on the inspection path. You cannot curl a pod from the internet.

Cite: LLD §2 / ADR-010. Do not defer — answer from the ADR.

Q6. What is a Transit Gateway and why do we need it?

The estate roundabout that already connects applications, edge firewalls and Direct Connect. We attach one spoke. We do not build an insurance-only hub.

Cite: Estate 18 / BE-01 / ADR-009. Do not defer — answer from the ADR.

Q7. Why not a second TGW / second Direct Connect for insurance?

The estate already has them. Cloning them is an architecture defect. Attach, do not clone (BE-01).

Cite: BE-01. Do not defer — answer from the ADR.

Q8. What is NAT? Why do we still have NAT if we use Apigee?

NAT lets private pods start outbound. It still sits on the inspection path toward Apigee. It is not what 1SB allowlists. 1SB allowlists Apigee's egress IPs (ADR-020).

Cite: ADR-010 remainder / ADR-020. Do not defer — answer from the ADR.

Q9. Please give us the IP list for 1SB now.

I will not invent IPs in this room. Action: Apigee team writes product + per-env IPs (DEP-20260914-apg). Dev uses stubs. That does not block vpc-dev.

Cite: DEP-20260914-apg. Defer OK. Shivanshi / API platform

Q10. Why Network Firewall instead of a FortiGate pair in our VPC?

FortiGate already exists in the hub edge VPC. Dropping another pair in the spoke clones firewall operations. Spoke NFW may inspect pod→Apigee; Security accepts that remainder.

Cite: ADR-010 / ASM-012. Defer OK. Deepali

Q11. Why F5 Distributed Cloud, not BIG-IP in AWS?

On this estate F5 is F5-XC SaaS, outside AWS. An in-VPC BIG-IP icon was a diagram mistake and was retracted in ADR-018.

Cite: ADR-018. Do not defer — answer from the ADR.

Q12. Why Cloudflare, not CloudFront?

Cloudflare Enterprise is the north-south CDN/DDoS standard for this perimeter. CloudFront would be a second CDN for the same job.

Cite: ADR-018. Do not defer — answer from the ADR.

Q13. Why Internal ALB, not NLB or a public Kubernetes LoadBalancer?

We need HTTP path routing: / to nip-web, /api to BFF. That is ALB. A Service type LoadBalancer with a public IP is the exposure we refused.

Cite: LLD §3. Do not defer — answer from the ADR.

Q14. Why EKS, not ECS or Lambda everywhere?

EKS is listed IaaS on this estate. Lambda-for-everything does not match long-running insurance journeys or private VPC-only data stores. We are not anti-Lambda; we are anti-rewriting the platform as functions.

Cite: LLD BOM / AP-09. Do not defer — answer from the ADR.

Q15. Why Java 21 / Spring Boot, not Node or .NET?

LTS, already in the programme, Spring Boot 3.5 in support. A language war does not change a trust boundary. We will not restart R0 on a new runtime.

Cite: Lifecycle paper. Do not defer — answer from the ADR.

Q16. Why not one InsuranceService monolith?

Every rule change would be a release, and Health later becomes a rewrite. Suitability and quote are different systems of record.

Cite: 03 SAD / R0-E2E §5. Do not defer — answer from the ADR.

Q17. Why Flutter?

One project, three artefacts: web, APK, IPA. Tokens never on the device. Three native apps would triple the control surface.

Cite: R0-E2E §2. Do not defer — answer from the ADR.

Q18. Why Keycloak if we have Active Directory?

AD is workforce only (TI-01). Partners must not enter AD. Workforce verification is the AD-verify API, never LDAP from EKS.

Cite: ADR-020 / TI-01. Do not defer — answer from the ADR.

Q19. Why not LDAP from EKS to AD? It is simpler.

LDAP from a workload cluster to AD is a new credential path and a new blast radius. The AD-verify API already exists. We call it privately through Apigee.

Cite: ADR-020. Do not defer — answer from the ADR.

Q20. Why is Dev inside UAT? That is not isolation.

Isolation is two VPCs, two route tables, namespaces, schemas and prefixes. Stubs cannot use the production CBS route. A second AWS account is a Cloud exception we are not requesting.

Cite: SUG-20260914-uat / ASM-017. Do not defer — answer from the ADR.

Q21. Why no CUG?

No R0 consumer for CUG. Waiver, do not provision (ASM-018).

Cite: ASM-018. Do not defer — answer from the ADR.

Q22. Why warm standby, not active-active?

NFR RTO is 1 hour. Warm standby in ap-south-2 matches that. Active-active is a different money and data problem. DR proof is sitting 2.

Cite: NFR-DR / LLD §11. Defer OK. Aarti + Shivanshi

Q23. Is DR proven?

No. Designed, not drilled (NFR-DR-04). I will not claim a restore time we have not measured.

Cite: NFR-DR-04. Do not defer — answer from the ADR.

Q24. Is this a Critical Information System?

Architecture proposes CIS because of CIF, KYC, suitability, payment orchestration and 7-year WORM. The register is Compliance + CISO. We do not self-classify.

Cite: CIS proposal. Defer OK. Shailja + CISO

Q25. Where is the VA/PT report?

It does not exist. CI has Checkstyle, Spotless, ArchUnit, JaCoCo, lockfile SCA. DAST/VA/PT is before UAT exit / production ARB. We will not pentest an environment we have not been allowed to vendor.

Cite: Pack row 11. Do not defer — answer from the ADR.

Q26. Why isn't OpenSearch / Kafka the audit store?

Search retention is not a 7-year licence evidence. Kafka topic retention is not WORM. Audit is INSERT-only + S3 Object Lock (TI-07, ADR-013).

Cite: ADR-013 / TI-07. Do not defer — answer from the ADR.

Q27. Why can't the RM pay on the iPad for the customer?

Customer-device payment is a control, not a UX preference. UAT demos use a customer-device step.

Cite: FF-14 / TB-6. Do not defer — answer from the ADR.

Q28. Why 1SB at all? Why not call insurers directly?

R0 uses 1SB as a provider route behind an adapter (TI-04). Direct insurer APIs are a later sibling adapter. The Hub contract does not change.

Cite: TI-04 / ADR-020. Do not defer — answer from the ADR.

Q29. Are we compliant with the landing-zone / SOP?

We attach to Control Tower, TGW, DX, EDGE, GitLab, Terraform, IAM IC, India SCPs. Differences are recorded ADRs: API Gateway inbound; no CUG; Dev-inside-UAT; no workload IGW. Human T4 still outstanding.

Cite: Estate 18 / ADR-018/020. Defer OK. Mahesh T4 + Shivanshi

Q30. Can we put Flutter on public S3?

No. No public buckets. Authenticated app is not a brochure site. Static assets come through nip-web on the same ingress chain.

Cite: LLD BOM / SOP. Do not defer — answer from the ADR.

Q31. Why not Istio / service mesh in R0?

Not in R0. We already have NetworkPolicy, PDP, and two reverse proxies. A mesh is a new control plane with no named R0 problem.

Cite: Lifecycle 'not in R0'. Do not defer — answer from the ADR.

Q32. Can we start Dev without Direct Connect?

Yes. Dev uses stubs. UAT needs VPN first, then existing DX as primary (ADR-009). Do not block vpc-dev on a carrier order.

Cite: ADR-009 / DEP-20260824-dx1. Do not defer — answer from the ADR.

Q33. Who signs T4 Architecture?

A human Mahesh, not this deck. We draft; we do not sign. Same for Security Board 4 and Compliance CIS.

Cite: Authority card. Do not defer — answer from the ADR.

Q34. Why Hyderabad, not another region?

India residency (TI-08) plus the DR region already in use (ap-south-2). Data does not leave India.

Cite: TI-08 / FF-08. Do not defer — answer from the ADR.

Q35. What if ARB wants a full production pack today?

We cannot evidence timed DR, VA/PT, or CIS registration today. Forcing those now either invents evidence or delays Dev/UAT indefinitely. We ask for a staged review.

Cite: This sitting's ask. Do not defer — answer from the ADR.